THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 5

Cryptography

Objectives

- Explain components of cryptographic protocols
- Explain common cryptography standards
- Describe modern cryptanalysis methods

© Cengage Learning 2014

Components of Cryptographic Protocols

- **Cryptography**: process of converting readable text, programs, and graphics into data that cannot be easily read or executed by unauthorized users
  - Converts **plaintext** into **ciphertext** by using an encryption algorithm
- Four goals of cryptography:
  - Confidentiality of information
  - Integrity of data
  - Authentication
  - Nonrepudiation

© Cengage Learning 2014

Cryptographic Primitives, Part 1

- Cryptographic primitives: modular mathematical functions that include encryption algorithms, hashing functions, pseudorandom number generators, and basic logical functions
  - Each primitive is designed to perform a specific task
    - Must be used with other primitives to provide adequate security
    - Example: encryption algorithm performs encoding but not message integrity
      - Combined with a hashing function, message integrity can be achieved

© Cengage Learning 2014

Cryptographic Primitives, Part 2

- Exclusive OR (XOR) Function
  - Used in cryptography as a linear mixing function to combine values
  - Based on binary bit logic
    - If x and y are the same (both true or both false) the output is 0 (false)
    - If x and y are different, the output is 1 (true)

x	y	xXORy
0	0	0
0	1	1
1	0	1
1	1	0

Figure 5-1 An XOR truth table

© Cengage Learning 2014

Cryptographic Primitives, Part 3

- Permutation Functions
  - Bit-shuffling permutation functions reorder sets of objects randomly
    - By rearranging input bits
    - Like shuffling a deck of cards
  - Expansion permutation (certain bits are used more than once)
    - Example: input 010 is rearranged and expanded into 0101

© Cengage Learning 2014

Cryptographic Primitives, Part 4

- Substitution Box (S-box) Functions
  - Transforms a number of input bits into a number of output bits
    - Produces a lookup table that can be fixed or dynamic
  - An S-box function is usually described as *n* input bits x *m* output bits
    - A 6x4 S-box means that 6 input bits are transformed into 4 output bits

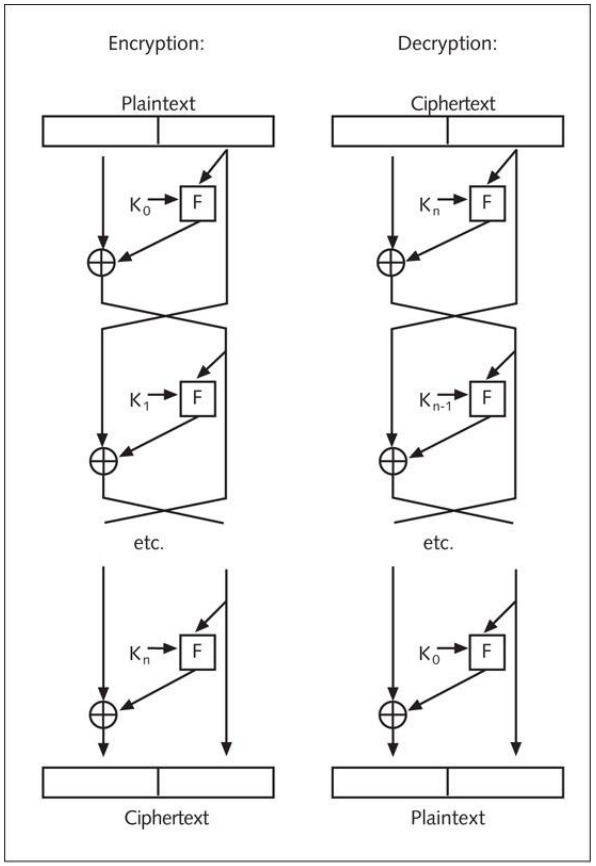
© Cengage Learning 2014

Cryptographic Primitives, Part 5

- Feistel Network
  - Symmetric block cipher that is the basis of several symmetric encryption algorithms
  - Purpose is to obscure the relationship between ciphertext and keys
  - Combines multiple rounds of repeated operations
    - Example: processing cleartext input with XOR functions
  - A key schedule is used to produce different keys for each round
  - Advantage: Encryption and decryption operations are similar or identical
    - Reduces size of its code and resources needed to use it

© Cengage Learning 2014

A Feistel Network



© Cengage Learning 2014

Figure 5-2 A Feistel network

Cryptographic Primitives, Part 6

- Pseudorandom Number Generators (PRNGs)
  - An algorithm for generating sequences of numbers that approximate random values
  - Many cryptographic functions require random values that serve as seeds for further computation:
    - *Nonces* – a number or bit string that prevents generation of the same ciphertext during subsequent encryptions of a message
    - *One-way functions* – include integer factorization, discrete logarithms, and the Rabin function
    - *Salts* – consists of random bits used as input for key derivation functions
    - *Key derivation* – generates secret keys

© Cengage Learning 2014

Cryptographic Primitives, Part 7

- Pseudorandom Number Generators (cont'd):
  - PRNGs can be hardware or software based
  - PRNG values are not completely random
    - Generated by a structured method
  - Cryptographically secure PRNGs (CSPRNGs) produce values that are random enough to suit the intended use
    - There is no certain way to determine the output of a CSPRNG without knowing the algorithm used and its initialization state

© Cengage Learning 2014

Cryptographic Primitives, Part 8

- Hashing functions
  - Generate a hash value or message digest from input
    - A hash value is a fixed-size string representing the original input's contents
  - Used to verify message integrity
    - Compares the message digest the sender calculates with the message digest the receiver calculates
      - If values are the same, the sender's message has not been altered during transmission
  - Also used for error detection
    - As with Cyclic Redundancy Check (CRC)

© Cengage Learning 2014

Encryption Algorithms, Part 1

- Computer algorithms provide exact instructions for which operations to carry out, which criteria change operations, how many times to perform an operation (called looping), and when to stop
  - A strict order of operations is essential (called control flow)
- Encryption algorithm is a set of precise instructions that provides an encoding function for a cryptographic system
  - Also combine with other primitives to perform integrity checking or authentication

© Cengage Learning 2014

Encryption Algorithms, Part 2

- Key Size in Encryption Algorithms
  - An encryption algorithm's strength is often tied to its key length
    - Longer the key, the harder it is to break
  - Key sizes have had to increase to keep up with brute-force attacks

© Cengage Learning 2014

Encryption Algorithms, Part 3

- Types of Encryption Algorithms
  - Block cipher – encrypts groups of text at a time
    - A block cipher encrypts the whole word *cat* instead of each letter
  - Stream cipher – encrypts cleartext one bit at a time
    - The letters *c*, *a*, and *t* in *cat* are encrypted separately
  - Symmetric algorithms – use the same key to encrypt and decrypt a message
    - Faster, more efficient method
  - Asymmetric algorithms – use a specially generated key pair
    - One key encrypts cleartext into ciphertext and other key decrypts

© Cengage Learning 2014

Encryption Algorithms, Part 4

- Blowfish
  - A 64-bit block cipher composed of a 16-round Feistel network and key-dependent S-box functions
  - Uses a variable key size from 32 to 448 bits (default size is 128 bits)
  - Fast in encryption and decryption operations
    - 64-bit block size is now considered too short
  - Still a widely used cipher

© Cengage Learning 2014

Encryption Algorithms, Part 5

- Twofish
  - Successor to Blowfish
  - A 128-bit symmetric block cipher composed of a 16-round Feistel network and key-dependent S-box functions
  - Has a complicated key schedule and a variable key size of 129, 192, or 256 bits
- Rivest Cipher Family
  - Popular stream cipher in Web browsers that use Secure Sockets Layer (SSL), Wired Equivalent Privacy (WEP), Wi-Fi Protected Access (WPA), and Transport Layer Security (TLS)

© Cengage Learning 2014

Encryption Algorithms, Part 6

- Rijndael (pronounced raindoll)
  - Encryption algorithm incorporated into the Advanced Encryption Standard (AES)
  - Block cipher composed of 10 to 14 rounds of S-box and XOR functions
- Rivest, Shamir, Adelman (RSA)
  - Uses a public key that is freely shared and a private key that is kept secret
  - Widely used in e-commerce protocols and is the default encryption and signing scheme for X.509 certificates

© Cengage Learning 2014

Hashing Algorithms, Part 1

- Hashing algorithms: sets of instructions applied to variable-length input that generate a fixed-length message
  - Do not provide confidentiality (do not encrypt the message)
  - Do provide verification that a message has not been altered
  - Most common are Message Digest 5 (MD5) and Secure Hash Algorithm

© Cengage Learning 2014

Hashing Algorithms, Part 2

- Message Digest 5 (MD5)
  - Makes only one pass on data and generates a 128-bit hash value
    - Displayed as a 32-character hexadecimal number
  - 3 conditions to make a hashing algorithm secure:
    - No hash should be usable to determine original input
    - No hashing algorithm should be run on the same input and produce different hashes
    - A hashing algorithm should not be run on two different inputs and produce the same hash (collision)

© Cengage Learning 2014

Hashing Algorithms, Part 3

- Secure Hash Algorithm (SHA)
  - National Security Agency designed SHA as a successor to MD5
    - Approved for federal government use
  - Used in SSL, SSH, and IPsec

Algorithm	Message digest length	Block size	Rounds of computation
SHA-1	160	512	80
SHA-224 and SHA-256	224/256	512	64
SHA-384 and SHA-512	384/512	1024	80

Table 5-1 Summary of SHA algorithms

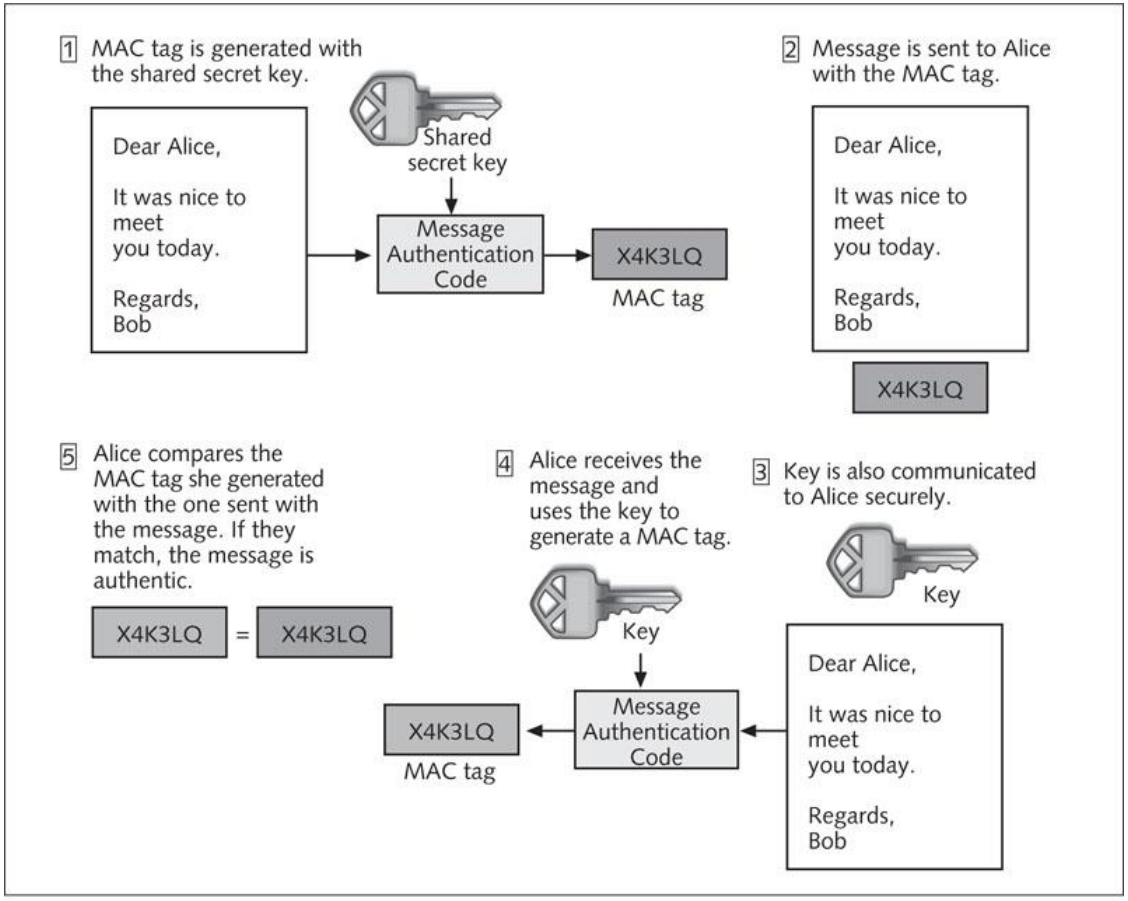
© Cengage Learning 2014

Message Authentication Code

- Message Authentication Code (MAC)
  - Also known as Message Integrity Check (MIC)
  - Uses a shared secret key that is agreed on by sender and receiver in the verification process to generate a MAC tag for a message
    - MAC tag is like an enhanced message digest
  - MAC uses a single key to verify message integrity
    - Challenge is key management – how to communicate the secret key that the sender and receiver use securely

© Cengage Learning 2014

The MAC Process



© Cengage Learning 2014

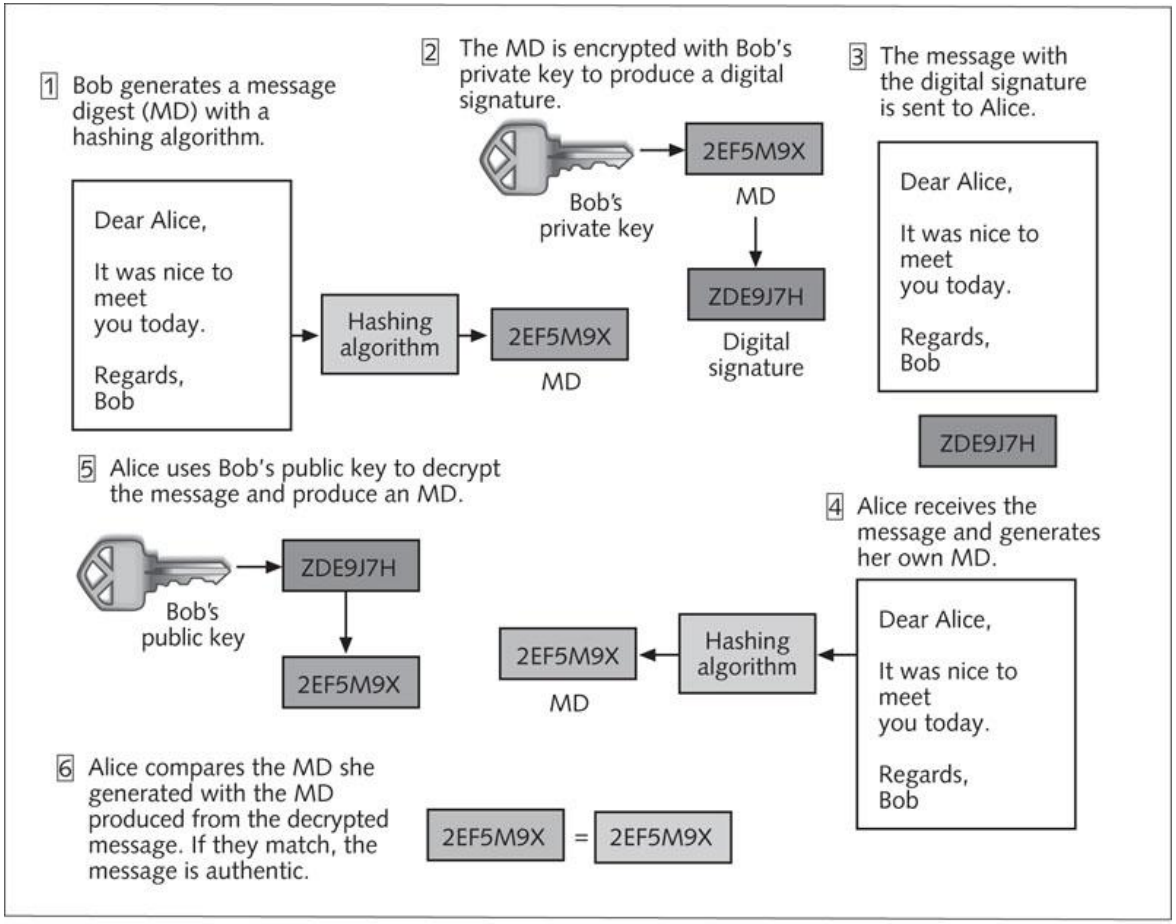
Figure 5-3 The MAC process

Digital Signatures

- Digital signatures use hashing algorithms with asymmetric encryption
  - Produces a method for verifying message integrity and nonrepudiation
  - Nonrepudiation: ensuring that participants in a message exchange cannot deny their roles

© Cengage Learning 2014

The Digital Signature Process



© Cengage Learning 2014

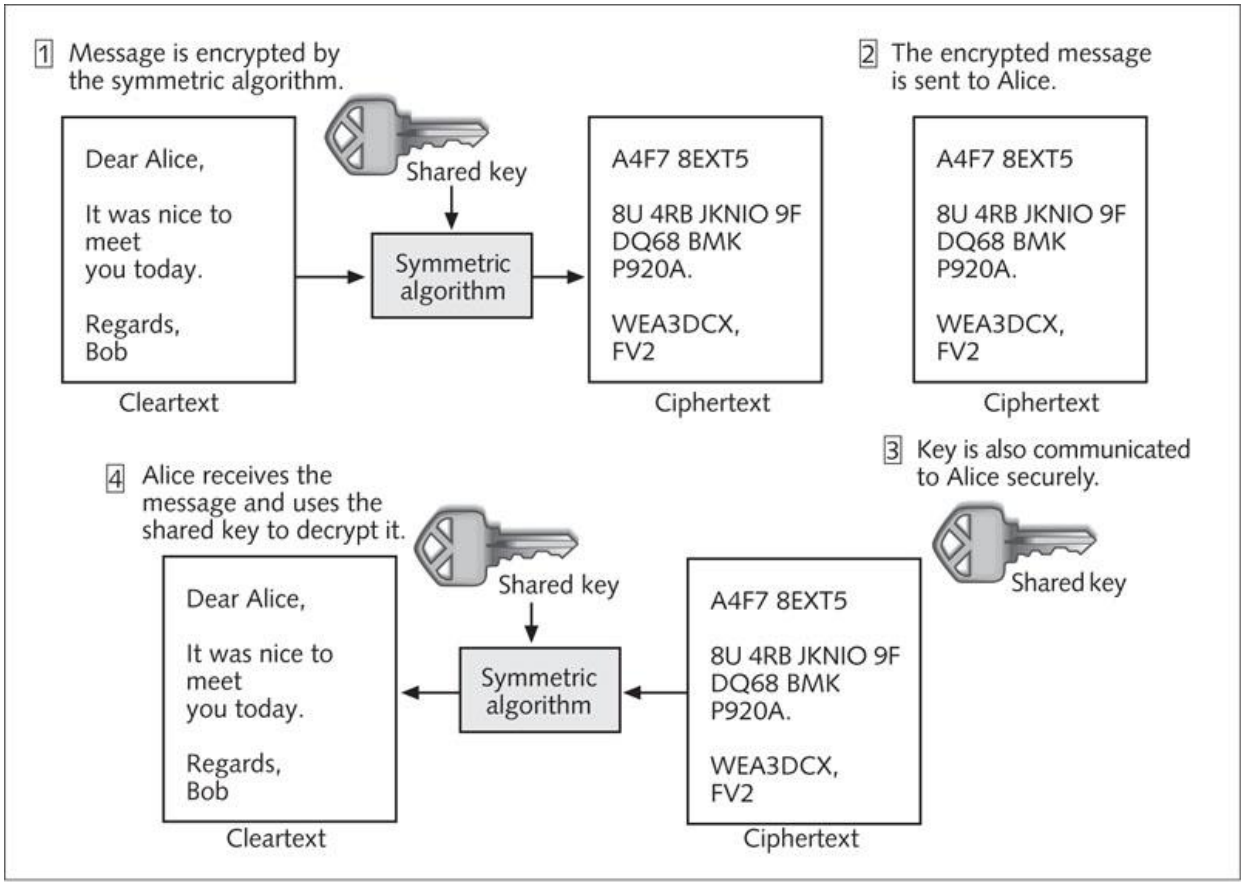
Figure 5-4 The digital signature process

Key Management, Part 1

- Major problem with cryptographic algorithms is secure key exchange
  - **Key management**: Process where cryptographic systems change keys frequently and distribute them to all authorized parties
    - Difficult to carry out reliably
- **Private Key Exchange**: uses a symmetric cryptographic algorithm in the encryption process
  - Same key (also called shared key) is used to encrypt and decrypt message
  - Message is only as secure as the shared key

© Cengage Learning 2014

The Private Key Exchange Process



© Cengage Learning 2014

Figure 5-5 The private key exchange process

Key Management, Part 2

- **Public key exchange**: uses asymmetric cryptography in the encryption process and generates a key pair
  - Anything encrypted by one key can only be decrypted by the other member of the pair
  - One key is labeled as public key and the other is labeled as private key
  - Public key is freely shared and private key is secure
  - Confidentiality is ensured
    - Private key owner is only one who can decrypt what the public key encrypted

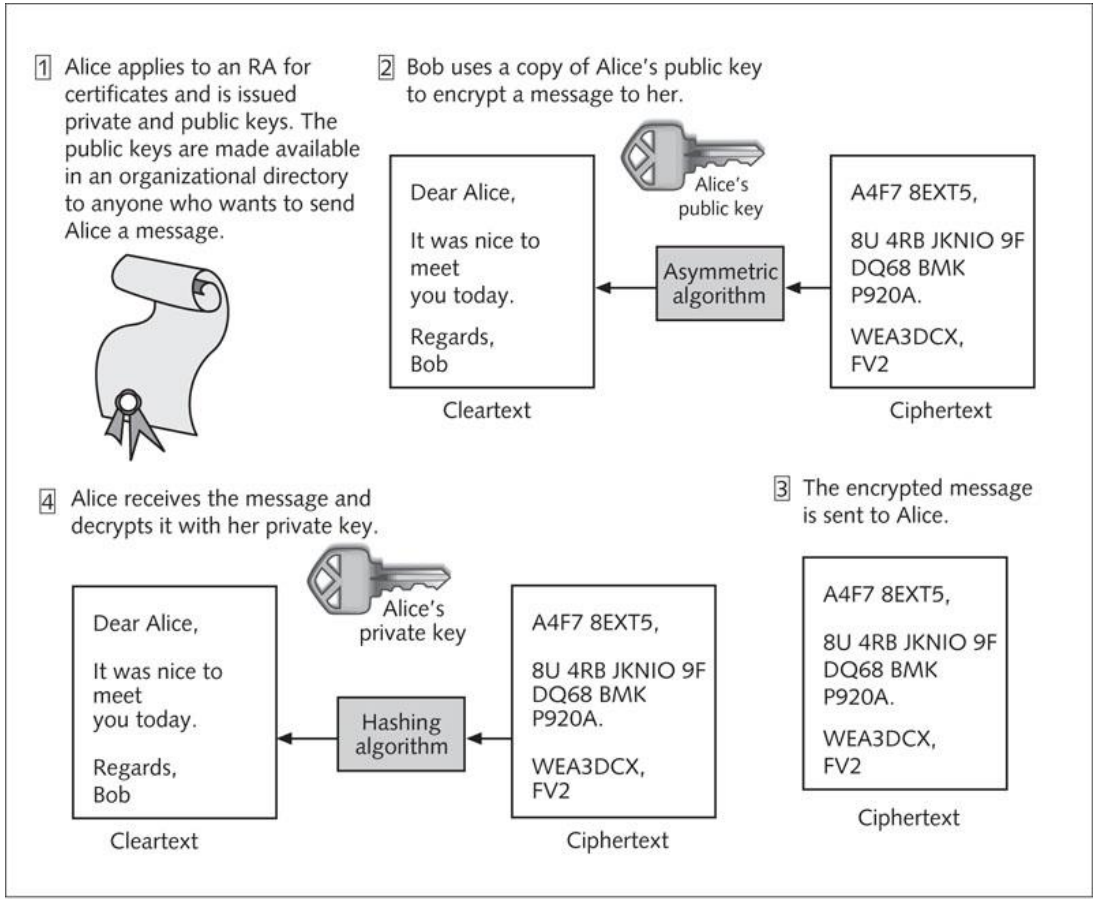
© Cengage Learning 2014

Key Management, Part 3

- Components of asymmetric cryptography:
  - *Certificates*-file that contains information about the user, service, or business entity and public key
  - *Certification authorities (CAs)*-organizations that issue public and private key pairs
  - *Registration authorities (RAs)*-also called registrars; serve as front end to users for registering, issuing, and revoking certificates
  - *Certificate revocation lists (CRLs)*-listings of invalid certificates
  - *Message digests*-check hash values to verify message is unchanged

© Cengage Learning 2014

The Public Key Exchange Process



© Cengage Learning 2014

Figure 5-6 The public key exchange process

Key Management, Part 4

- Public Key Cryptography Standards (PKCSs)
  - Created by RSA labs to improve interoperability
  - Not actual industry standards
- X.509
  - An International Telecommunication Union standard for PKI
  - Specifies standard formats for public key certificates, a strict hierarchical system for CAs issuing certificates, and standards for CRLs
  - Use RSA for key generation and encryption

© Cengage Learning 2014

Examining Cryptography Standards

- Cryptographic protocol - incorporates a detailed description of standardized requirements and guidelines for:
  - Key generation and management
  - Authentication
  - Encryption
  - Hashing functions
  - Nonrepudiation
- Reasons for standardizing cryptographic protocols:
  - Interoperability
  - Reliability
  - Scalability

© Cengage Learning 2014

Data Encryption Standard

- Data Encryption Standard (DES)
  - Developed by IBM and selected in 1976 as a Federal Information Processing Standard (FIPS)
  - Federal laws mandate its use in certain government projects
  - Has been adopted internationally
  - Composed of a 16-round Feistel network with XOR functions, permutation functions, 6x4 S-box functions, and fixed key schedules
    - DES generates 64 bits of ciphertext from 64 bits of plaintext by using a 56-bit key

© Cengage Learning 2014

Triple DES

- Triple DES (3DES)
  - A more current and secure variation of DES
  - Ciphertext goes through three iterations (round of encryption)
    - Uses three separate 64-bit keys to process the same bit of unencrypted text
    - First key encrypts, second key decrypts, and third key encrypts it again
  - Triple DES requires more processing time and resources

© Cengage Learning 2014

3DES Encryption

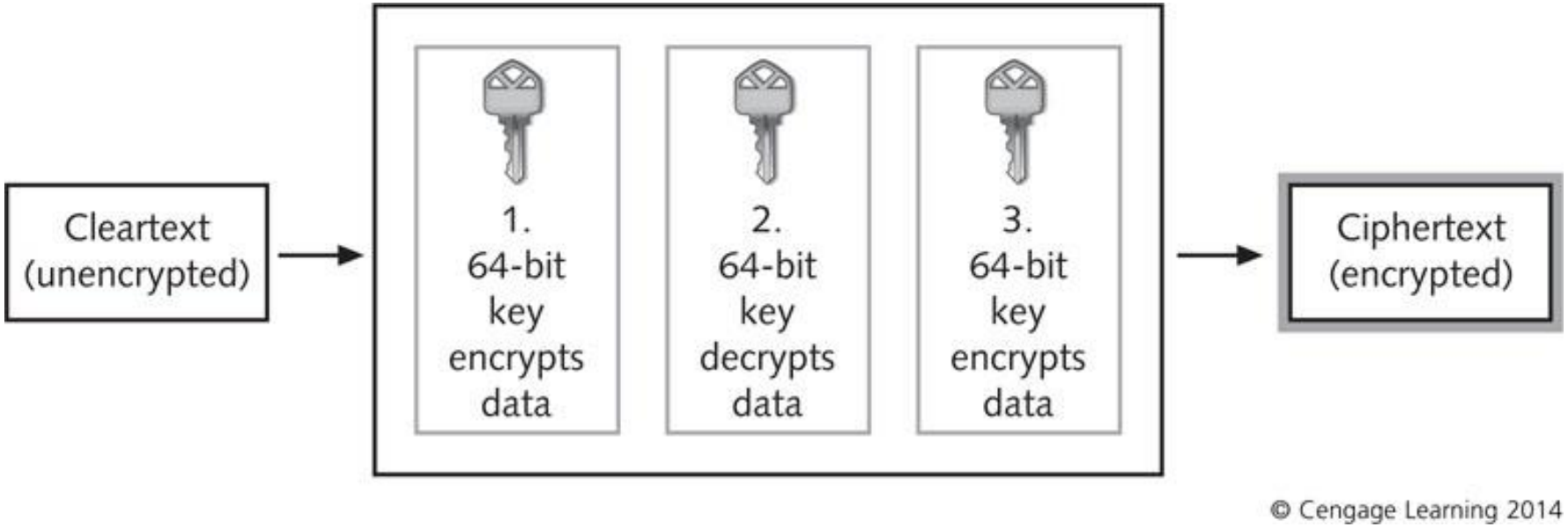


Figure 5-7 3DES encryption

Advanced Encryption Standard

- Advanced Encryption Standard (AES)
  - Approved by National Institute of Standards and Technology (NIST) for US government use
  - Stronger than 3DES and works faster
  - Currently the most widely used encryption method
  - As of early 2012, no successful attacks against AES have occurred

© Cengage Learning 2014

Internet and Web Standards, Part 1

- **Secure Shell (SSH)** – provides authentication and encryption of TCP/IP packets
  - Works primarily with Linux and UNIX systems
  - Windows versions are also available
  - Uses public key cryptography
  - When a client initiates an SSH connection:
    - Two computers exchange keys and negotiate algorithms for authentication and encryption

© Cengage Learning 2014

Internet and Web Standards, Part 2

- **Secure Sockets Layer (SSL) “ Depricated “**
  - Developed by Netscape Communications Corporation
  - A secure way to transmit data on the Web
  - Uses asymmetric keys to start an SSL session and exchange secret keys
    - After session is established, SSL uses dynamically generated symmetric keys for rest of transfer

© Cengage Learning 2014

Internet and Web Standards, Part 3

Transport Layer Security(TLS)"Multiple Versions"

- Designed to provide additional security
- Similar to SSL in operation and design
- Adds the following:
  - Uses a hashed message authentication code (HMAC) that combines hashing algorithm with a shared secret key
  - Splits input data in half
    - Processes each half with a different hashing algorithm then recombines them with an XOR function
- Uses symmetric keys for bulk encryption and asymmetric keys for authentication and key exchange

© Cengage Learning 2014

Internet Protocol Security, Part 1

- Internet Protocol Security (IPsec)
  - Set of standard procedures the IETF developed for securing communication on the Internet
  - IPsec has become the standard set of protocols for securing tunneled communications because:
    - IPsec works at Layer 3
    - IPsec can encrypt an entire TCP/IP packet
    - IPsec was originally developed for use with IPv6
      - Also works with current IPv4
    - IPsec authenticates source and destination computer before data is encrypted or transmitted
  - IPsec is standardized and supported by a variety of hardware and software devices

© Cengage Learning 2014

Internet Protocol Security, Part 2

- When an IPsec connection is established:
  - Two computers authenticate one another and establish the Security Association (SA) settings
    - SA is a relationship between two or more parties that describes how they use security services to communicate
- Each IPsec connection can perform encryption, encapsulation, authentication, or a combination of all three
- With Windows Server 2008 and Windows 7, IPsec is integrated with Windows Firewall with Advanced Security snap-in

© Cengage Learning 2014

Internet Protocol Security, Part 3

- IPsec components:
  - *Internet security Association Key Management Protocol (ISAKMP)* – enables two computers to agree on security settings and establish an SA
  - *Internet Key Exchange (IKE)* – enables computers to exchange keys to make an SA
  - *Oakley* – enables IPsec to use the Diffie-Hellman encryption algorithm to create keys
  - *IPsecurity Policy Management* – service that retrieves IPsec security policy settings from Active Directory and applies them to computers in the domain
  - *IPsec driver* – handles task of encrypting, authenticating, decrypting, and checking packets

© Cengage Learning 2014

Internet Protocol Security, Part 4

- Authentication Header (AH): an IPsec component that authenticates TCP/IP packets
- With AH:
  - Packets are signed with a digital signature
    - Tells other IPsec devices it originated from IPsec
  - AH adds a header that is calculated by IP header and data values
    - Values are calculated with a hashing algorithm and a key

© Cengage Learning 2014

AH Message Exchange

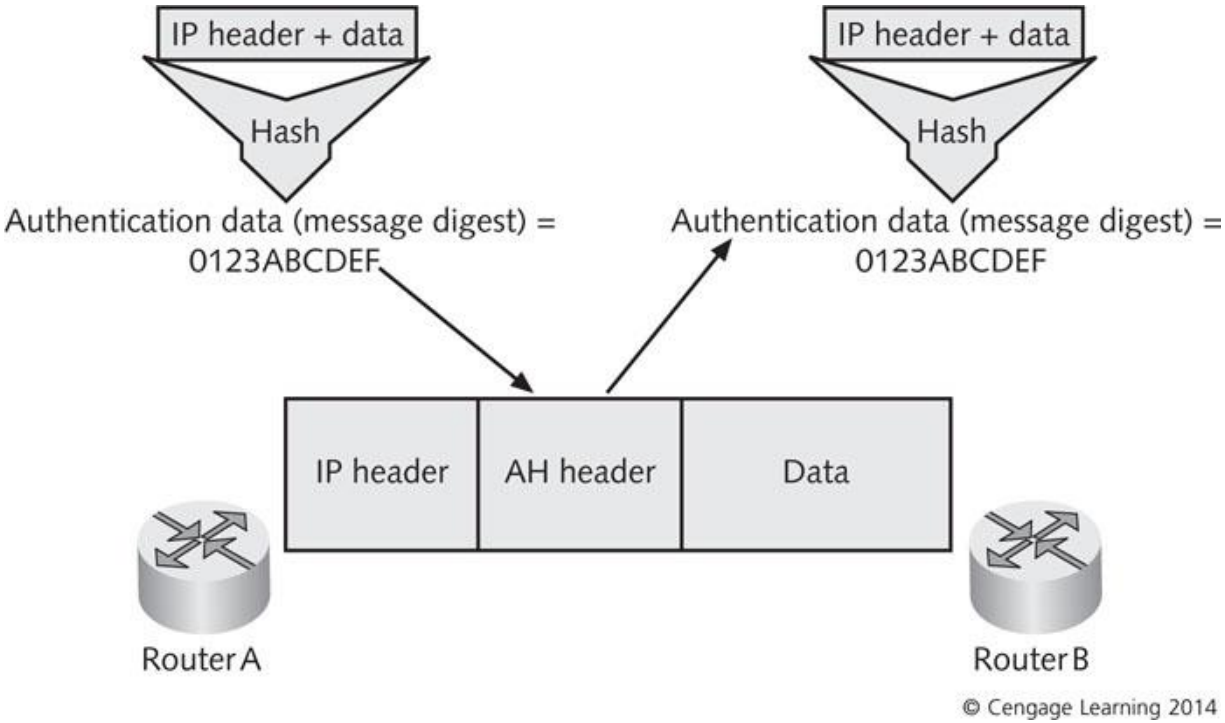


Figure 5-8 AH message exchange

Internet Protocol Security, Part 5

- AH works differently in the two IPsec modes:
  - Tunnel mode: AH authenticates the entire original header and builds a new IP header
    - Only fields not authenticated by AH are fields that can change in transit
  - Transport mode: AH authenticates the data and the original IP header
    - Authenticated except fields changed in transit

© Cengage Learning 2014

AH in Tunnel and Transport Modes

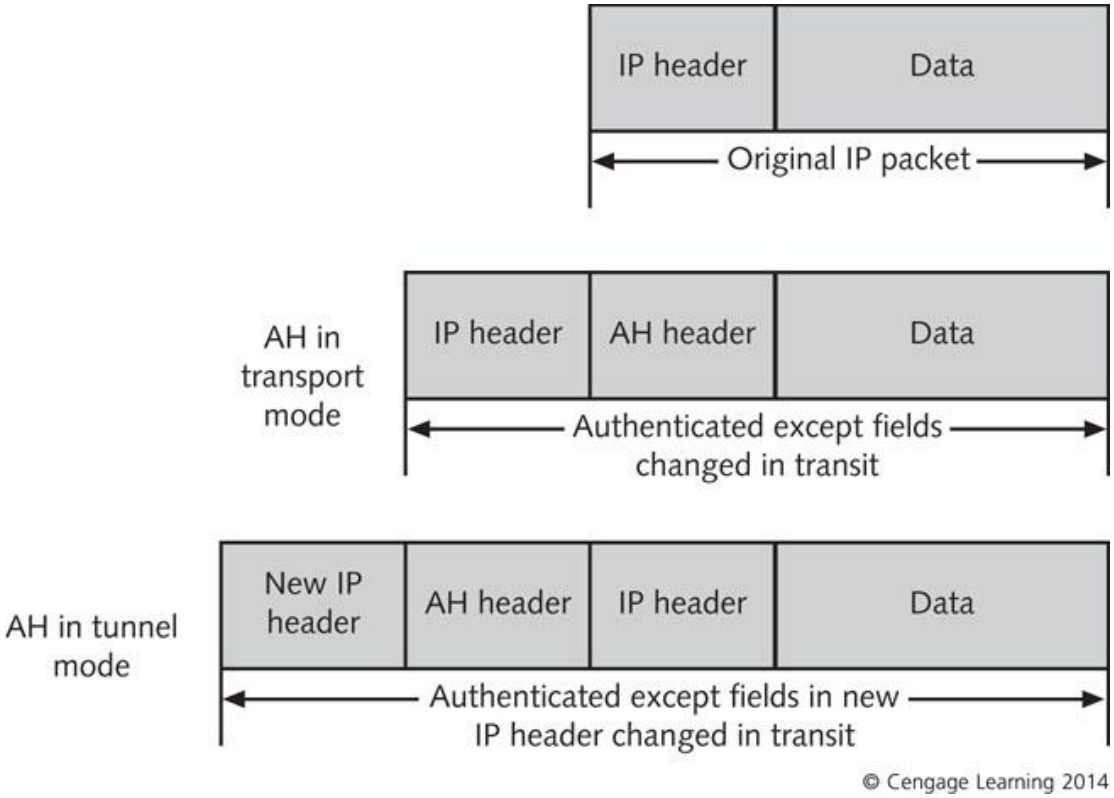


Figure 5-9 AH in tunnel and transport modes

Internet Protocol Security, Part 6

- Encapsulating Security Payload (ESP)
  - Ensures confidentiality of data
  - In tunnel mode: ESP encrypts both header and data
  - In transport mode: ESP encrypts only data

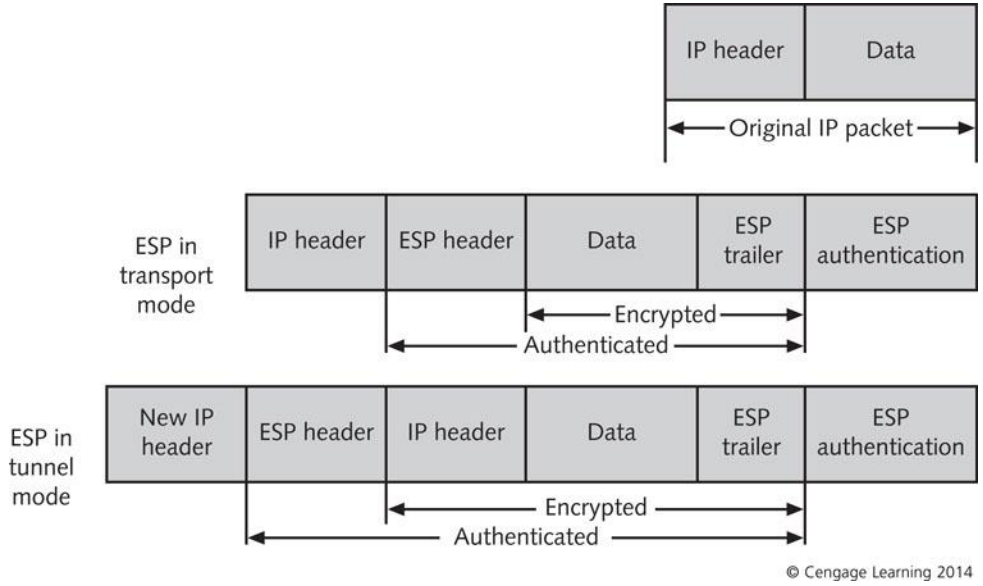


Figure 5-10 ESP in tunnel and transport modes

© Cengage Learning 2014

Modern Cryptanalysis Methods

- Cryptanalysis: study of breaking encryption methods
  - New attacks emerge constantly
  - Security professionals must keep up to date on threats and countermeasures
  - Rely on expertise of mathematicians who design algorithms

© Cengage Learning 2014

Side Channel Attacks

- Attacks underlying systems that leak information
  - Leaks are unintentional signals (emanations) that could expose information being processed
  - Types of side channel attacks:
    - Timing attacks
    - Power monitoring attacks
    - Acoustic cryptanalysis
    - Radiation monitoring
    - Thermal imaging attack
  - Countermeasures include power conditioning and UPSs, shielding, and strong physical security

© Cengage Learning 2014

Passive Attacks

- Cryptanalysts observe data being transmitted
  - Eavesdrop on transmissions
  - Detecting this kind of attack is difficult
  - Countermeasures focus on using strong encryption

© Cengage Learning 2014

Chosen Ciphertext and Chosen Plaintext Attacks

- Chosen ciphertext attack: attacker selects a captured encrypted message and decrypts it with an unknown key
  - Sometimes uses a decryption oracle (a device that decrypts ciphertext messages)
  - Can be prevented by using correct cryptographic padding values or redundancy checks
- Chosen plaintext attack: attacker selects arbitrary plaintext messaged to be encrypted
  - Public key encryption algorithms that are not randomized are vulnerable
  - Countermeasures are based on randomized encryption

© Cengage Learning 2014

Related Key Attacks

- A form of cryptanalysis in which attackers can observe a cipher's operation by using several different keys
  - Initial values are unknown, but a mathematical relationship connecting the keys is known
  - Wired Equivalent Privacy (WEP) failed because of related key attacks
    - WPA2 or 802.11i is recommended to be used instead of WEP
  - To defend against related key attacks, use of a cryptographic protocol (such as AES) is advised

© Cengage Learning 2014

Integral Cryptanalysis

- This attack uses sets of chosen plaintext messages that share a common constant
  - Each set of messages shares a constant value, and the remainder of each plaintext message is tried with all possible variables
- Applicable to block ciphers that use a substitution-permutation network
  - Rijndael, Twofish, and IDEA are examples

© Cengage Learning 2014

Differential Cryptanalysis

- This attack examines how differences in input affect the output
  - Uses pairs of plaintext messages related by a constant difference
  - By computing differences, attackers might be able to find statistical patterns
- Applies mainly to block ciphers but can also be used against stream ciphers and hashing functions
- Goal of cryptographers is to prevent or mask predictable behavior

© Cengage Learning 2014

Summary, Part 1

- Cryptography is the process of converting plaintext into ciphertext by using an encoding function
- Cryptographic primitives are modular mathematical functions that are building blocks of cryptography
- An encryption algorithm is a set of instructions that provides the encoding function to a cryptographic system
- Symmetric algorithms use a shared key in a private key exchange
- Asymmetric algorithms use two keys

© Cengage Learning 2014

Summary, Part 2

- Digital signatures use hashing algorithms with asymmetric encryption for verifying message integrity
- Public-key Infrastructure (PKI) components include certificates, certification authorities (CAs), registration authorities (RAs), certificate revocation lists (CRLs), and message digests
- Cryptographic protocols describe how algorithms should be used
  - DES, 3DES, and AES are examples

© Cengage Learning 2014

Summary, Part 3

- Wireless network cryptographic protocols include WEP, WPA, and 802.11i
- Internet security protocols include SSL, SSH, and TLS
- IPsec is a cryptographic protocol used for Internet, VPN, and network security
- Attacks on cryptographic systems include side channel attacks, passive attacks, chosen ciphertext and chosen plaintext attacks, random number generator attacks, and XSL attacks

© Cengage Learning 2014